

# ResolvX

## Policy Exception Governance Policy

Topic-Specific Policy - Exception Authority, Duration & Review

POL-026 · v1.0 · 2026 · Internal : Restricted

### Document Information

|                |                                                                      |
|----------------|----------------------------------------------------------------------|
| Policy ID      | POL-026                                                              |
| Version        | 1.0                                                                  |
| Status         | Active                                                               |
| Classification | Internal - Restricted                                                |
| Owner          | GRC Lead                                                             |
| Approver       | CISO                                                                 |
| Review Cycle   | Annual                                                               |
| Next Review    | Q3 2027                                                              |
| Frameworks     | ISO 27001:2022 Clause 6.1.3, 10.1 · NIST CSF 2.0 GV.RM · SOC 2 CC3.2 |

## 1. Purpose

This Policy Exception Governance Policy establishes who has authority to approve an exception to any ResolvX policy, how long that exception may last, and how it is reviewed until it closes.

Several ResolvX policies already reference an exception process and the Policy Exception Register. This policy is the single authoritative source for how that process actually works, so approval authority scales with what's actually being excepted rather than treating a Low-risk convenience request and a Critical-tier control waiver identically.

## 2. Scope

This policy governs every exception request against any ResolvX POL-0XX policy. Where an individual policy's own Exceptions section states a specific approval authority, this policy's tiered structure (§4) takes precedence as the individual policy's clause exists to notify the reader an exception process exists, not to independently define it.

## 3. Relationship to Risk Management (POL-014)

A policy exception and a risk acceptance are closely related but distinct decisions. A risk acceptance under POL-014 §5 is a broader acknowledgment that a given risk exists and will be tolerated. A policy exception under this policy is narrower and more specific: a time-limited waiver of one particular control requirement, for one particular reason, expiring on a defined date. An exception often reflects an underlying accepted risk, but the exception itself is what gets tracked, time-boxed, and reviewed here.

## 4. Tiered Exception Approval Authority

Approval authority mirrors the risk acceptance structure already established in POL-014 §5, applied to exception requests specifically. The tier is set by the classification or criticality of what the exception affects — the system, data, or control's own tier under POL-004 or POL-008's Business Impact Analysis — not by who is asking.

| Affected Tier | Approval Authority      | Notes                                                                                                                      |
|---------------|-------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Critical      | CISO, with CEO notified | Reserved for genuinely exceptional circumstances where a Critical-tier control exception is not a routine convenience.     |
| High          | CISO                    | Documented rationale required in the Policy Exception Register.                                                            |
| Moderate      | GRC Lead                | Standard approval path for most operational exception requests.                                                            |
| Low           | GRC Lead                | Still logged and time limited. A Low-tier exception is not exempt from the register simply because the stakes are smaller. |

## 5. Exception Duration

| Affected Tier  | Maximum Duration Without Renewal                                  |
|----------------|-------------------------------------------------------------------|
| Critical       | 30 days                                                           |
| High           | 60 days                                                           |
| Moderate / Low | 90 days - consistent with the standard already set in POL-002 §13 |

A shorter maximum duration for higher-tier exceptions reflects that the underlying condition creating the need for the exception should be resolved faster, the higher the stakes involved.

## 6. Exception Request Process

- Requester submits a written request to GRC Lead, identifying the specific policy and section, the business justification, and the requested duration.
- GRC Lead determines the affected tier (§4) and routes the request to the correct approval authority, here the requester does not self-select their own approver.
- An approved exception is logged in the Policy Exception Register with its approval date, expiry date, and approving authority before it takes effect, an exception is not in force until it is logged.
- A denied request is documented in the register as denied, not simply left unrecorded, so the request itself remains part of the audit trail.

## 7. Review & Renewal

GRC Lead reviews exceptions approaching their expiry date and either closes them (the underlying condition is resolved) or processes a renewal with updated justification, following the same approval tier as the original request, here a renewal is not automatic, and a Critical-tier exception cannot be renewed indefinitely on the strength of its original approval alone. All active exceptions are reviewed as part of the quarterly risk report under POL-014 §7, so exception volume and duration are visible at the same cadence as the rest of ResolvX's risk posture.

## 8. Roles & Responsibilities

### 8.1 GRC Lead

- Owns this policy and the Policy Exception Register.
- Determines the affected tier and routes requests to the correct approval authority (§4).
- Reviews approaching-expiry exceptions (§7).

### 8.2 CISO

- Approves High and Critical-tier exceptions (§4).

### 8.3 CEO

- Notified of any Critical-tier exception at the time of approval.

## 9. Compliance and Enforcement

An exception granted outside the approval authority defined in §4, or one that continues in practice past its logged expiry date without a documented renewal, is treated as a control deficiency and logged in the Corrective Action Plan.

# 10. Document Control

|                      |                                                                                                                                                                                                           |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Policy ID            | POL-026                                                                                                                                                                                                   |
| Version              | 1.0                                                                                                                                                                                                       |
| Status               | Active                                                                                                                                                                                                    |
| Classification       | Internal - Restricted                                                                                                                                                                                     |
| Owner                | GRC Lead                                                                                                                                                                                                  |
| Approver             | CISO                                                                                                                                                                                                      |
| Review Cycle         | Annual                                                                                                                                                                                                    |
| Next Review          | Q3 2027                                                                                                                                                                                                   |
| Framework References | ISO/IEC 27001:2022 Clause 6.1.3, 10.1 · NIST CSF 2.0 GV.RM · SOC 2 TSC CC3.2                                                                                                                              |
| Related Documents    | POL-002 (Acceptable Use Policy), POL-010 (Patch Management Policy), POL-014 (Risk Management Policy), POL-023 (HR Security Policy), POL-025 (Clean Desk & Clear Screen Policy), Policy Exception Register |

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

## Authorisation

| Role     | Name | Date |
|----------|------|------|
| CEO      |      |      |
| CISO     |      |      |
| GRC Lead |      |      |